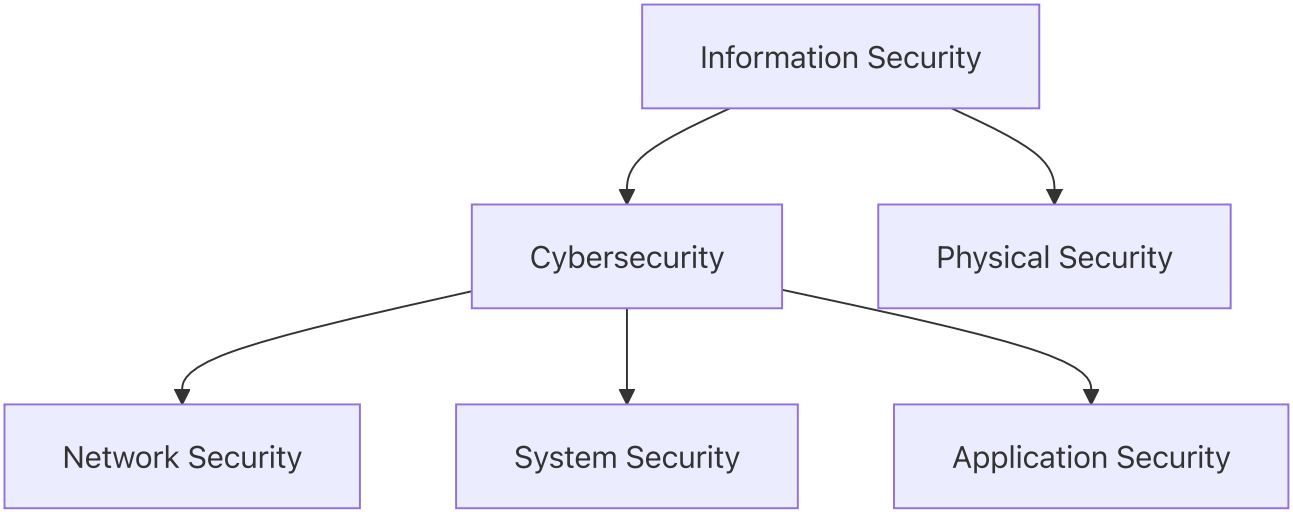
Lecture 1

> **Overview**
>
> This note expands on the foundational concepts of Information Security. It provides a deeper look into the CIA Triad and clearly breaks down the boundaries and overlaps between Cybersecurity, System Security, and Network Security.

Breaking Down the Security Domains

It is easy to confuse these terms, but they represent different layers of defense.

> **The Hierarchy of Protection**
>
> "All Cybersecurity is Information Security, but not all Information Security is Cybersecurity."



Information Security (InfoSec)

This is the widest category. It covers the protection of *all* data, no matter where it lives or what form it takes.

- Scope: It includes digital data on a hard drive, spoken secrets in a meeting room, and physical paper files in a locked drawer.
- Goal: To protect the value of information itself.

Cybersecurity

This domain lives inside Information Security. It focuses entirely on protecting *digital* information and electronic systems from attacks that come from the internet or other digital networks.

- **Scope:** Defending against malware, ransomware, phishing emails, and remote hackers.
- **Goal:** To defend the digital infrastructure from malicious cyber threats.

Network Security

This is a specialized branch of Cybersecurity. If you think of computers as houses, Network Security is about guarding the roads connecting those houses.

- **Scope:** Protecting data while it is moving (in transit).
- **Tools:** Firewalls to block bad traffic, VPNs to encrypt data traveling over the internet, and Intrusion Detection Systems to watch for suspicious network behavior.
- **Goal:** To stop attackers before they can even reach the computers.

System Security

This is another specialized branch. Returning to the house analogy, System Security is about locking the doors and windows of the house itself.

- **Scope:** Protecting individual devices (servers, laptops, smartphones) and their internal operating systems.
- **Tools:** Antivirus software, regular operating system updates (patching), and full disk encryption.
- **Goal:** To ensure the standalone machine is locked down, even if the network it connects to is unsafe.

Detailed Domain Comparison

Domain	Core Focus	Key Tools & Methods	Real-World Target
Information Security	Data everywhere (digital and physical)	Filing cabinets, shredders, policies	Protecting a printed patient medical record
Cybersecurity	Digital data and systems	Threat hunting, incident response	Stopping a ransomware group
Network Security	Data in transit (moving)	Routers, firewalls, Wi-Fi passwords	Blocking a hacker from private Wi-Fi
System Security	Data at rest (stored)	Antivirus, OS patching, user	Preventing malware from installing on a

Domain	Core Focus	Key Tools & Methods	Real-World Target
		accounts	laptop

> ⁝☰ A Complete Security Scenario
>
> Imagine you are sending a highly sensitive financial report to your boss.
>
> 1. You put a password on the document so only your boss can open it. This is Information Security (specifically, Confidentiality).
> 2. You connect to the company VPN so the internet provider cannot read the email as it sends. This is Network Security.
> 3. Your company's email server scans the incoming file to make sure a hacker didn't attach a virus to it. This is System Security.
> 4. The entire framework that allows your company to monitor these steps and respond if something goes wrong is Cybersecurity.

The Core Concept: The CIA Triad

The CIA Triad is the gold standard for evaluating how secure a system or organization really is. Every security rule, tool, and policy is created to support at least one of these three pillars.

1. Confidentiality

Confidentiality means keeping secrets safe. It ensures that sensitive information is only seen by people or systems that have the right to see it.

- **How it works:** We use *access controls* (like usernames and passwords) and *encryption* (scrambling data so it cannot be read without a key).
- **Failure example:** A hacker steals a database of customer credit card numbers and posts it online. This is a massive breach of confidentiality.

2. Integrity

Integrity means keeping data accurate and trustworthy. It ensures that information is not changed, deleted, or corrupted by accident or by malicious actors.

- **How it works:** We use *hashing* (creating a unique mathematical fingerprint for a file) and strict *permissions* (only allowing certain users to edit files).

- **Failure example:** An angry employee alters the company payroll spreadsheet to pay themselves twice as much. The data has lost its integrity.

3. Availability

Availability means keeping systems online and data accessible. It ensures that authorized users can get to the information whenever they need it.

- **How it works:** We use *backups*, *redundant servers* (having a backup server ready if the main one fails), and *surge protection*.
- **Failure example:** A hacker floods a website with fake traffic so real customers cannot log in (a DDoS Attack). The system has lost its availability.

Lecture 2

Advanced Security Models and Frameworks

Overview

This document expands upon foundational security concepts by introducing advanced frameworks like the Parkerian Hexad, the NIST regulatory playbook, specialized environments, and the application of modern Threat Intelligence.

The Domain Hierarchy

Defining the Boundaries

Information Security (InfoSec) is the broad parent discipline. It protects all forms of data, including physical paper, human knowledge, and digital files. It utilizes physical locks, corporate policies, and document shredders.

Cybersecurity is a specialized subset of InfoSec. It strictly protects digital assets, networks, and hardware using technical controls like firewalls, encryption, and antivirus software.

Core Security Models

The models below form the theoretical basis for all data protection strategies and threat assessments.

The CIA Triad

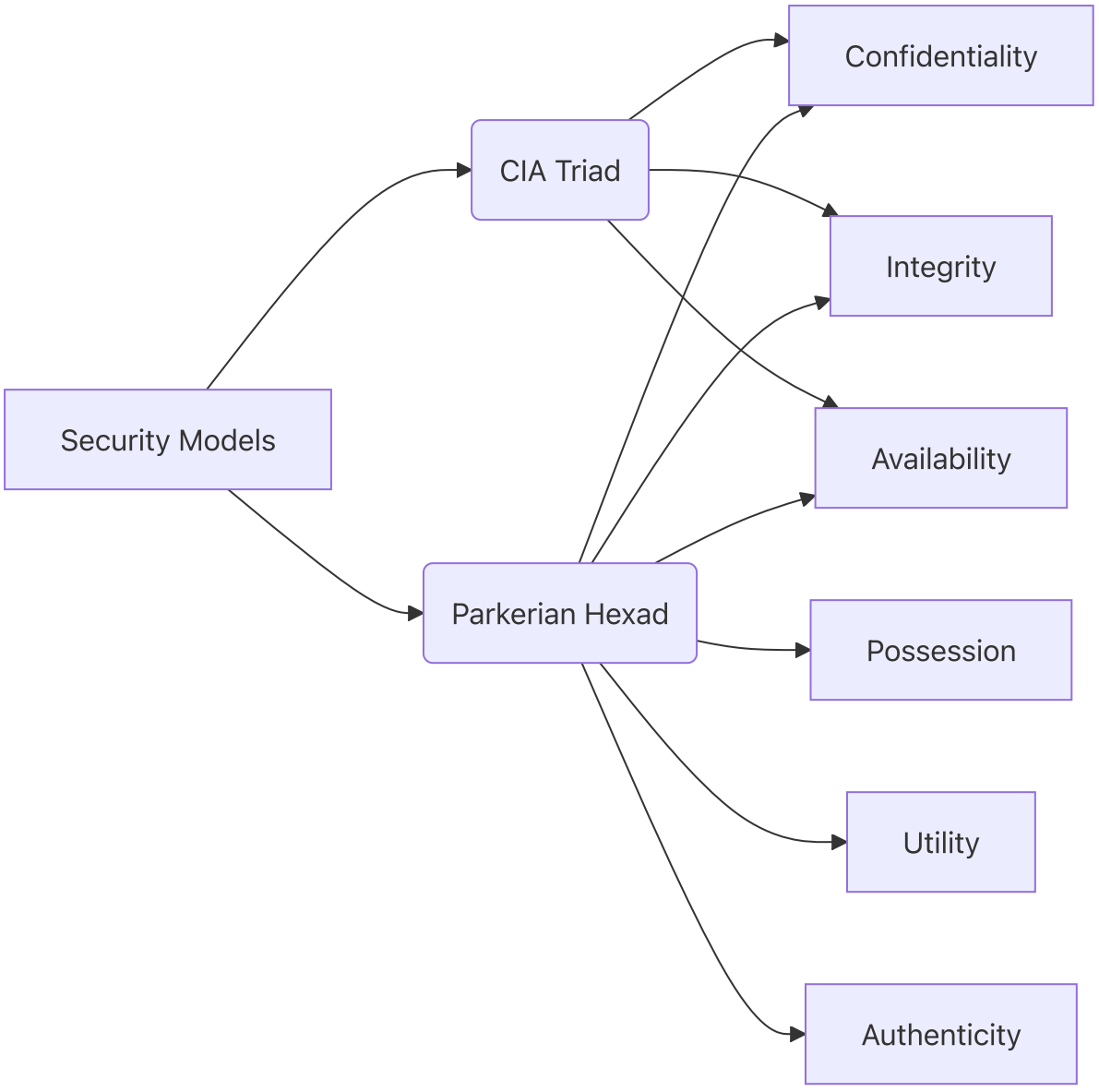
The universal standard for security design rests on three pillars:

- Confidentiality: Keeping data secret from unauthorized people.
- Integrity: Ensuring data has not been tampered with or modified.
- Availability: Ensuring systems and data are accessible when needed.

The Parkerian Hexad

This model expands upon the CIA Triad, adding three extra layers for more complex Threat Modeling:

Hexad Element	Definition	Real-World Context
Possession (Control)	Holding the physical or digital asset.	If a thief steals an encrypted hard drive, the data is still confidential, but you have lost possession.
Utility	The data is in a usable format.	If you lose the decryption key to your own file, it is secure but has lost utility.
Authenticity	Verifying the true source.	Ensuring an email sender or system user is genuinely who they claim to be.



The NIST Playbook

The National Institute of Standards and Technology (NIST) sets the standard for how government and private sectors secure their systems.

Risk and Categorization

- FIPS 199: Categorizes the potential impact of a data breach as *Low*, *Moderate*, or *High*.
- High Water Mark: A rule stating a system's overall risk rating must equal its highest individual CIA rating.

> **High Water Mark Concept**
> If a system's Confidentiality is rated Low, but its Availability is rated High, the entire system must be protected at a High level.

- NIST SP 800-30: The official manual for Risk Assessment. It calculates risk by multiplying the *likelihood* of a threat by its potential *impact*.

Security Controls (NIST SP 800-53)

This is the main catalog of actual defenses deployed based on the FIPS 199 rating.

Control Family	Identifier	Purpose
Access Control	AC	Enforces *Least Privilege*, ensuring users only get the access they absolutely need to do their jobs.
Audit and Accountability	AU	Involves logging and tracking all system actions for forensic investigations.
Incident Response	IR	Creating strategic plans for how to stop an active attack and recover normal operations.
Supply Chain Risk	SR	Vetting third-party vendors to prevent outside contamination of the network.

Specialized Security Environments

Different computing environments require entirely unique security approaches and priorities.

- Zero Trust (NIST SP 800-207): Operates on the strict assumption that the network is already breached. It never trusts a user simply because they are inside the building or VPN. It continuously verifies user identity and device safety before granting access.
- Operational Technology (OT - NIST SP 800-82): Used for physical infrastructure like power grids and factory floors. In OT, Availability and Integrity are prioritized over Confidentiality because system downtime can cause physical harm or death.
- Cloud Computing (NIST SP 800-145): Operates on a *shared responsibility* model. The cloud provider secures the physical servers and infrastructure, while the customer is responsible for securing the data and access policies inside them.

Legal and Regulatory Reporting

Organizations are legally required to report breaches to government bodies promptly.

> Mandatory Disclosures
>
> - SEC Form 8-K (Item 1.05): Public companies must publicly report any material cyber incident (one that causes significant financial or reputational damage) within 4 business days.
> - CIRCIA: Critical infrastructure sectors (hospitals, power grids, banks) must report substantial cyber incidents to CISA within 72 hours, and must report any ransom payments within 24 hours.

Applied Threat Intelligence

Modern security relies heavily on AI and automated systems to detect and report threats rapidly.

Combating Phishing with AI

The PhiUSIIL dataset is a massive database of both legitimate and malicious URLs. It is used to train AI models to spot phishing attempts without relying on simple, easily bypassed lists of blocked websites.

Instead of just reading words, the AI looks for structural red flags:

- Overly long URLs.
- Direct IP addresses (which intentionally bypass normal DNS routing).
- Strange character repetition.
- Lookalike domains (for example, replacing a lowercase letter 'l' with the number '1').

Lecture 3

Core Concepts of Information Security and Threat Terminology

Overview

This document defines the foundational purpose of Information Security, refines the definitions of Authentication and Authorization, and builds a precise vocabulary for describing Threats and Attacks.

Core Concepts of Information Security

Authentication

Definition

Authentication specifically means verifying the identity of a person, system, or service, typically by checking credentials such as a password, token, or biometric factor against a known identity claim. It answers the question *"are you who you say you are?"*, not a general question about reality.

Authorization

Definition

Authorization is the process of granting access to a verified identity, defining what that identity is permitted to do once inside the system.

Threats and Attacks Terminology

The terms below are frequently confused with one another. Precision matters because they describe different stages of the same event chain.



Vulnerability

Vulnerability: A weakness or fault in a system that could potentially be exploited.

Threat

> **Definition: Threat vs. Attack**
>
> Calling a DDoS attack an example of a *"threat"* blurs the line between two different stages. A Threat is the *potential* for a danger to be realized, such as the general possibility that a malicious actor could flood your servers. The DDoS attack itself is the realized Attack, not the threat. The threat is the standing possibility; the attack is the actual event that exploits it. It is also worth noting a threat does not have to be continuous; it can be a one-time potential danger as well as an ongoing category of risk.

Threat Agent

Threat Agent (or threat actor): A specific person, object, or entity, such as an attacker, hacker group, or malicious insider, that carries out or poses a danger to the system.

Attack

> **Definition**
>
> An attack is more precisely defined as *an attempt to exploit a vulnerability*, whether or not that attempt succeeds. A blocked attack is still an attack; it just did not result in damage.

Vector

> **Definition**
>
> The carrier or delivery mechanism that transports an attack to its target, such as a malicious email attachment, an infected USB drive, or a compromised website link.

Exposure

> **Definition**
>
> Exposure describes a state where a system or data is *accessible or vulnerable to potential harm*, typically due to a misconfiguration or unintentional disclosure, **before** or independent of any actual exploitation. A device that has already been exploited is

better described as *compromised*. Confusing the two collapses the distinction between "at risk" and "already breached."

Incident

Definition

An incident is typically defined as the actual event or occurrence that violates security policy or threatens data, including the breach itself, not only what happens afterward. The recovery and effects that follow are usually addressed separately, under Incident Response.

Summary Table

Term	Correct Definition	Common Mistake to Avoid
Vulnerability	A weakness in a system	Confusing with an active threat
Threat	Potential for danger to be realized	Treating a specific attack as the threat itself
Threat Agent	The person or entity behind the danger	Conflating agent with the threat concept
Vector	The delivery mechanism of an attack	Confusing with the attack itself
Attack	An attempt to exploit a vulnerability	Assuming damage must occur
Exposure	A state of being accessible to risk, before exploitation	Assuming it only applies after a breach
Incident	The actual event or breach	Reducing it to only the aftermath

---

Lecture 4

Foundations of Information Systems and IAM

Overview

This document covers the foundational building blocks of information systems, including Identity and Access Management (IAM), the five core Information System Components, and the three tiers of Management and Decision Structures.

Identity and Access Management

The Three Pillars of IAM

Authentication is the process used to determine the identity of people, systems, or services.

Authorization is the process of granting access to groups or users based on defined roles.

Accountability and Responsibility are core principles that work alongside authentication and authorization, tracking who did what and who owns the outcome.

Role-Based Access Levels

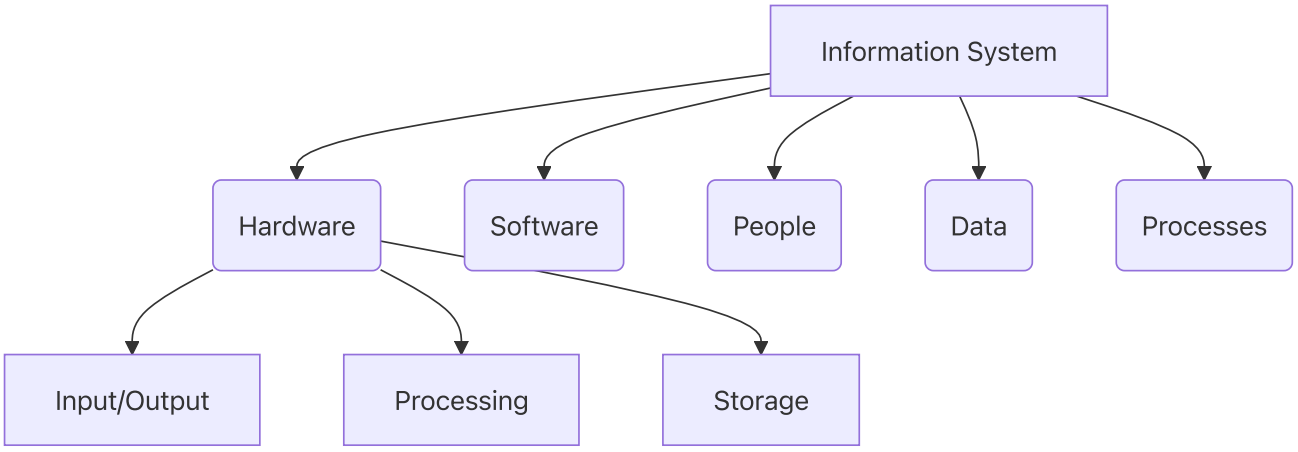
Role	Access Granted
Frontline Users	Read-only
Admin	Read and write
Manager	Read, write, and access control
IT Professional	Read, write, and execute
Higher-ups (CEO)	Complete access

A Point Worth Questioning

This hierarchy is not universal. In many real-world Role-Based Access Control (RBAC) models, an *Admin* is granted execute permissions too, since administrative tasks often require running scripts or system commands. If your source separates Admin (read/write) from IT Professional (read/write/execute), treat this as a simplified

teaching model rather than an industry standard, and confirm which definition your course expects on an exam.

Information System Components



Hardware

- Input/Output: Monitors, speakers, microphones.
- Processing: CPU, GPU, RAM, Motherboard.
- Storage: Hard disk, SSD, HDD.

> **RAM Is Not Storage**
>
> RAM is usually placed in both the *Processing* and *Storage* categories. That double placement is worth flagging. RAM is *volatile memory*: it holds data temporarily for active processing and is wiped when power is lost. It supports the CPU during processing, which is why it belongs there. However, it does not belong under *Storage*, which refers to *non-volatile* devices like the Hard disk, SSD, and HDD that retain data permanently. Keeping RAM only under Processing will make your model more accurate.

Software

Includes System Software, Application Software, and network devices such as Network Interface Cards (NIC).

People

Individuals interacting with the system, including Users (clients, frontline users), IT Professionals, and Managers.

Data

The raw information processed by the system.

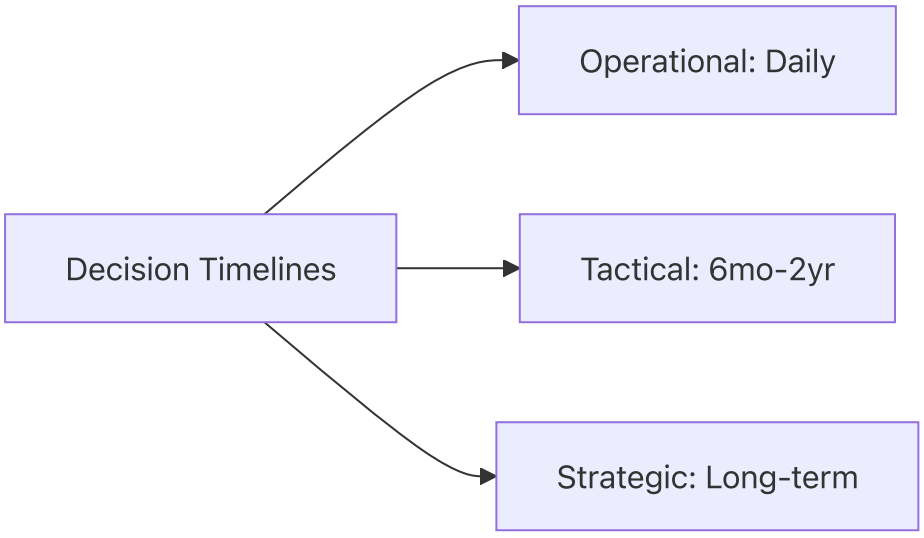
Processes

The rules, procedures, standards, and ongoing steps required to operate the system.

Management and Decision Structures

Tier	Decision Type	Timeline	Typical Owner	Example
Operational Management	Structured	Daily	Frontline staff	POS operations, daily inventory restocking
Tactical Management	Semi-structured	6 months to 2 years	Directors and staff	Hiring and firing employees
Strategic Management	Unstructured	Long-term	Executives	Setting organizational direction

> **Management Is Long-Term, Not Just "Near Future"**
>
> Since Operational Management covers daily tasks and Tactical Management covers 6 months to 2 years, Strategic Management should logically extend *beyond* that window, typically covering multi-year or long-term organizational direction (3 to 5+ years), not the near future. Consider revising your notes to reflect that Strategic Management sits at the far end of this timeline spectrum.



General Concepts

Probabilistic vs. Deterministic

Probabilistic systems involve uncertainty and produce outcomes that vary. Deterministic systems involve 100 percent certainty, always producing the same output from the same input.

Definition

The Internet is fundamentally defined as a *"network of networks."*

Lecture 5

Information Flow and Risk Assessment

Overview

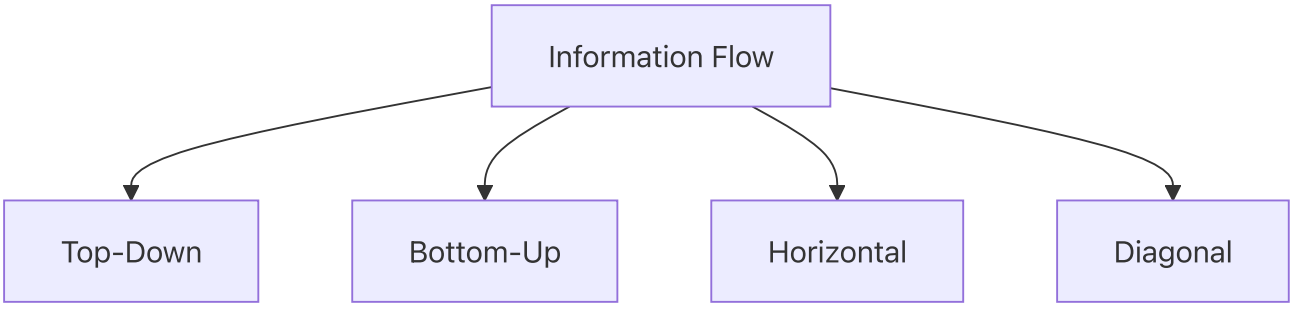
This document covers the four Information Flow approaches within an organization, the fundamentals of Risk Assessment, and the Quantitative Risk Assessment formulas used to justify security spending.

Information Flow

Definition

Information Flow is the exchange of information among people, processes, and systems within an organization.

The Four Approaches



Approach	Direction	Used For	Example
Top-Down Approach	Downward through hierarchy	Strategic decisions	CEO to Director to Manager to Admin to Technical staff
Bottom-Up Approach	Upward through hierarchy	Operational decisions	Frontline staff reporting issues to management
Horizontal Approach	Lateral, same level	Cross-functional coordination	Purchase Manager, Product Manager, Quality Control Manager, and Sales Manager exchanging updates
Diagonal Approach	Crosses both hierarchy and department lines	Informal or cross-functional urgent coordination	A Sales Manager communicating directly with an IT Technician in another

Approach	Direction	Used For	Example
			department, bypassing the normal chain

Risk Assessment

> **Core Formula**
>
> Risk = Likelihood x Impact

Likelihood Scale

Level	Value
Very Low	1
Low	2
Medium	3
High	4
Very High	5

Impact

Impact is defined as how much damage an event could cause to the system.

Risk Severity Scale

Severity	Score Range
Low	1
Medium	2 to 3
High	3 to 4
Severe	4 to 5
Critical	5

> **Overlapping Ranges**
>
> This severity scale has overlapping boundaries. A score of 3 falls under both *Medium* and *High*, and a score of 4 falls under both *High* and *Severe*. In practice, risk matrices

usually assign each score to exactly one band (for example, 1 = Low, 2 = Medium, 3 = High, 4 = Severe, 5 = Critical).

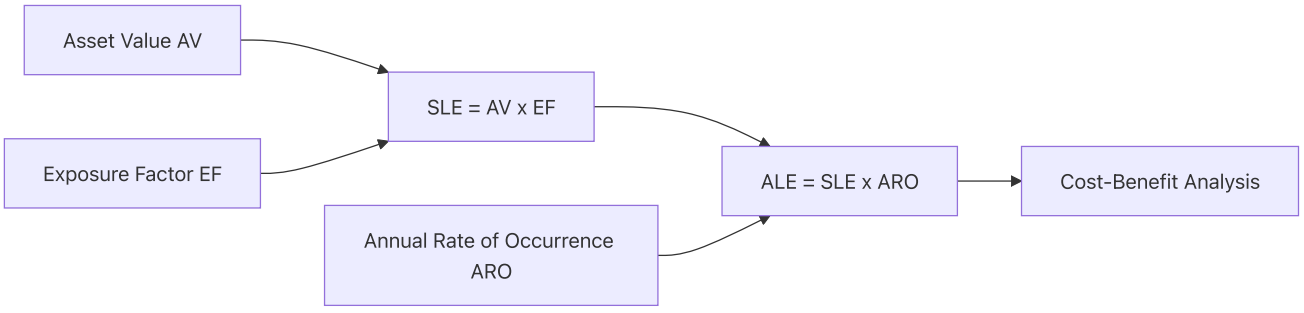
Threats vs. Vulnerabilities

Term	Definition
Threat	An event, incident, or continuous danger to the system
Vulnerability	A weakness, gap, or fault in the system
Relationship	Vulnerabilities are exploited by threats

> Exam Note
>
> Scenario-based questions are likely to appear on the exam. Practice applying the Risk, ALE, and SLE formulas to short word problems, not just memorizing the definitions.

Quantitative Risk Assessment Formulas

> Formula Chain
>
> These formulas build on each other: Single Loss Expectancy (SLE) feeds into Annual Loss Expectancy (ALE), which then feeds into the Cost-Benefit Analysis for a control.



Single Loss Expectancy (SLE)

Formula: `SLE = AV x EF`

Variable	Meaning
AV	Asset Value, the monetary worth of the asset

Variable	Meaning
EF	Exposure Factor, the percentage of the asset expected to be lost in a single incident

Annual Loss Expectancy (ALE)

Formula: `ALE = SLE x ARO`

Variable	Meaning
SLE	Single Loss Expectancy, calculated above
ARO	Annual Rate of Occurrence, how many times the event is expected to happen per year

Cost-Benefit Analysis for Controls

Justification Formula

A security control is justified when:

`(ALE before control) – (ALE after control) > Cost of control`

In other words, a control is only worth implementing if the money it saves in reduced annual losses exceeds what it costs to deploy and maintain.

Worked Scenario

Suppose a server (AV = 50,000) has an Exposure Factor of 40 percent if compromised, and this is expected to happen twice a year (ARO = 2).

SLE = 50,000 x 0.40 = 20,000

ALE = 20,000 x 2 = 40,000

If a firewall costing 10,000 per year reduces ALE to 10,000, the savings are 40,000 - 10,000 = 30,000, which is greater than the 10,000 cost. The control is justified.
